Revisión de seguridad

MIEEF Coach · 3 de noviembre de 2026

Revisión del código y la configuración de la aplicación: manejo de llaves, autenticación, permisos entre coaches, subida de archivos y dependencias. No es una prueba de penetración: es una auditoría de lo construido, con evidencia en el código.

Resultado general

Crítico	**0**	Nada que impida salir a producción.
Alto	**1**	Sin límite de intentos en el acceso y en las funciones que cuestan dinero.
Medio	**4**	Aislamiento en código, tope de texto, cabeceras, dependencias.
Bajo	**4**	Detalles de robustez y de higiene.

1 · LLAVES Y AMBIENTE LOCAL

Las llaves viven en .env.local, que está fuera de Git. Lo verifiqué: ningún archivo de entorno está en el repositorio y el token de monday no aparece en el historial.

SUPABASE_URL	Dato público	No es secreto
SUPABASE_SERVICE_ROLE_KEY	Secreto crítico	Entra a todo: lee y borra sin RLS
DEEPSEEK_API_KEY	Secreto de gasto	Consume saldo si se filtra
OPENAI_API_KEY	Secreto de gasto	Consume saldo si se filtra
MONDAY_API_TOKEN	Secreto de lectura	Lee los tableros de CEDEM

- La llave de servicio de Supabase es la más delicada: no tiene límites ni permisos por fila. Si se filtra, hay que rotarla y revisar quién tuvo acceso.
- El token de monday se compartió por chat y ya se regeneró. Conviene regenerar también la llave de Supabase si alguna vez se pegó en una captura o en un mensaje.
- OpenAI y DeepSeek: se pueden poner topes de gasto mensual en sus paneles. Vale la pena hacerlo antes de abrir el uso a los coaches.
- Falta una variable propia para firmar las ligas de calendario (CALENDARIO_SECRETO). Hoy usa la llave de Supabase; si esa llave cambia, todas las ligas se rompen.

2 · LO QUE CONVIENE CORREGIR

Sin límite de intentos en el acceso ni en las funciones de IA

ALTO

No hay tope de intentos de contraseña, ni de mensajes al agente, ni de análisis por hora. Una cuenta filtrada podría vaciar el saldo de las APIs en minutos, y el acceso admite intentos ilimitados.

Cómo se corrige: agregar un límite por usuario y por IP (por ejemplo 10 intentos cada 15 minutos y 60 mensajes por hora), y un tope de gasto en las consolas de DeepSeek y OpenAI.

El aislamiento entre coaches está en el código, no en la base — MEDIO

La aplicación entra con la llave de servicio, que se salta las reglas por fila de Supabase. Toda la separación depende de que cada consulta compare el coach. Hoy lo hace en todas las rutas que revisé, pero un descuido futuro sería una fuga silenciosa.

Cómo se corrige: mover la verificación a la base con reglas por fila y un token por usuario, o concentrar el acceso en una sola capa que siempre exija el coach.

La extracción de archivos no tiene tope de texto — MEDIO

Un documento comprimido puede descomprimirse a cientos de megabytes y agotar la memoria del servidor. El límite de 50 MB es del archivo, no de lo que produce al abrirse.

Cómo se corrige: cortar el texto extraído en un máximo (por ejemplo 2 millones de caracteres) y rechazar el archivo si lo rebasa.

Faltan cabeceras de seguridad — MEDIO

La aplicación no envía CSP, HSTS, X-Content-Type-Options ni Referrer-Policy. Sin ellas, el navegador queda más expuesto a contenidos incrustados y a filtraciones de la URL de origen.

Cómo se corrige: declararlas en next.config.ts; una CSP conservadora toma media hora y no rompe nada.

Dos dependencias con vulnerabilidad alta — MEDIO

npm audit reporta image-size (usada por pptxgenjs) con bucles infinitos al leer imágenes JXL, HEIF e ICNS. En esta aplicación solo generamos presentaciones con el logotipo propio; no le pasamos imágenes de usuarios, así que el riesgo real es bajo.

Cómo se corrige: actualizar pptxgenjs cuando publique la versión corregida; mientras tanto, el uso actual no la expone.

Las transcripciones pueden alterar al agente — BAJO

Un archivo subido podría contener instrucciones dirigidas al modelo. El impacto es una respuesta equivocada, no una fuga: el agente solo ve los datos de ese coach.

Cómo se corrige: reforzar la instrucción de que la transcripción es material a analizar, nunca órdenes.

Mensajes de error con detalle interno — BAJO

Once respuestas muestran el mensaje crudo de la base de datos, que puede revelar nombres de columnas o de tablas.

Cómo se corrige: cambiar el detalle por un mensaje genérico y dejar el detalle solo en el registro del servidor.

El proxy de archivos de monday acepta cualquier URL de monday.com — BAJO

Un usuario con sesión podría pedir por esa ruta recursos de monday ajenos al tablero. Requiere conocer la liga firmada y el token no viaja al navegador.

Cómo se corrige: restringir los dominios permitidos a los de archivos (cdn y files de monday).

Las ligas de calendario no caducan — BAJO

El feed usa una firma correcta y compara en tiempo constante, pero la liga es permanente: quien la tenga ve el calendario de ese coach para siempre.

Cómo se corrige: dejar la opción de revocarla desde Mi cuenta generando una firma nueva.

3 · LO QUE YA ESTÁ BIEN RESUELTO

- La cookie de sesión es httpOnly, SameSite Lax y Secure en producción, con ocho horas de vigencia.
- La llave de servicio de Supabase nunca llega al navegador: no hay variables NEXT_PUBLIC ni claves en componentes de cliente.
- Todas las rutas revisadas exigen sesión, y las que devuelven datos de un alumno verifican que sea

suyo.
• El almacenamiento de archivos es privado y se entrega con ligas firmadas que caducan.
• El token del calendario se compara en tiempo constante, sin filtrar información por el tiempo de respuesta.
• Desactivar a un coach le corta el acceso en la siguiente petición, sin esperar a que venza la sesión.
• No hay inyección de HTML: la interfaz no usa dangerouslySetInnerHTML en ningún punto.

4 · QUÉ HARÍA, EN ORDEN

1	Tope de intentos y de gasto	**Alto**	Media jornada
2	Cabeceras de seguridad	**Medio**	Media hora
3	Tope de texto al extraer	**Medio**	Media hora
4	Mensajes de error genéricos	**Bajo**	Una hora
5	Reglas por fila en la base	**Medio**	Un día, con pruebas
6	Actualizar pptxgenjs	**Medio**	Cuando publique
7	Revocar ligas de calendario	**Bajo**	Media jornada

Nada de esto impide usar la aplicación hoy. Los tres primeros puntos se resuelven en una tarde y cubren lo que un atacante intentaría primero: adivinar contraseñas y gastar saldo ajeno.